

ANALYSE FORENSIQUE RESEAU AVEC WIRESHARK

Type : Forensique réseau

Niveau : Intermédiaire

Outils : Wireshark, Analyse PCAP

Compétences démontrées : Analyse protocolaire, filtrage de trafic, énumération d'hôtes, détection de menaces.

Table des matières

Présentation.....	3
Environnement	3
Partie 0 : Evaluation du protocole Telnet	4
Qu'est-ce que Telnet ?	4
Pourquoi c'est un risque de sécurité ?	4
Partie 1 : Analyse de l'infection.....	4
Etape 1 : Identification du Three-Way	4
Etape 2 : Identification des IPs et des ports source/destination	5
Etape 4 : Filtrage du trafic http	5
Etape 5 : Enumération de l'hôte via le filtrage IP	6
Etape 6 : Décomposition des paquets http	6
Etape 7 : Adresses IP communiquant sur notre filtre http mis à l'étape 6	7
Etape 8 : Trouver le User-Agent	7
Etape 9 : Identification du FQDN et du fichier malveillant.....	8
Etape 10 : Point à savoir sur la segmentation TCP et gestion des gros paquets.....	8

Présentation

Ce TP simule une investigation forensique réel sur un réseau compromis. A partir d'un fichier **.pcap** capturé, j'analyse le trafic réseau pour identifier les machines infectées, découvrir les activités malveillantes, reconstituer le comportement de l'attaquant et extraire les indicateurs de compromission (IOC).

Environnement

Outils : Wireshark

Plage réseau : 10.10.10./24

Type d'investigation : Analyse forensique post-compromission

Partie 0 : Evaluation du protocole Telnet

Qu'est-ce que Telnet ?

Telnet est un protocole d'accès à distance fonctionnant sur le port 23, permettant de contrôler une machine distante via une interface en ligne de commande.

Pourquoi c'est un risque de sécurité ?

Malgré son usage ancien, Telnet est considéré comme non sécurisé dans les environnements d'aujourd'hui pour plusieurs raisons :

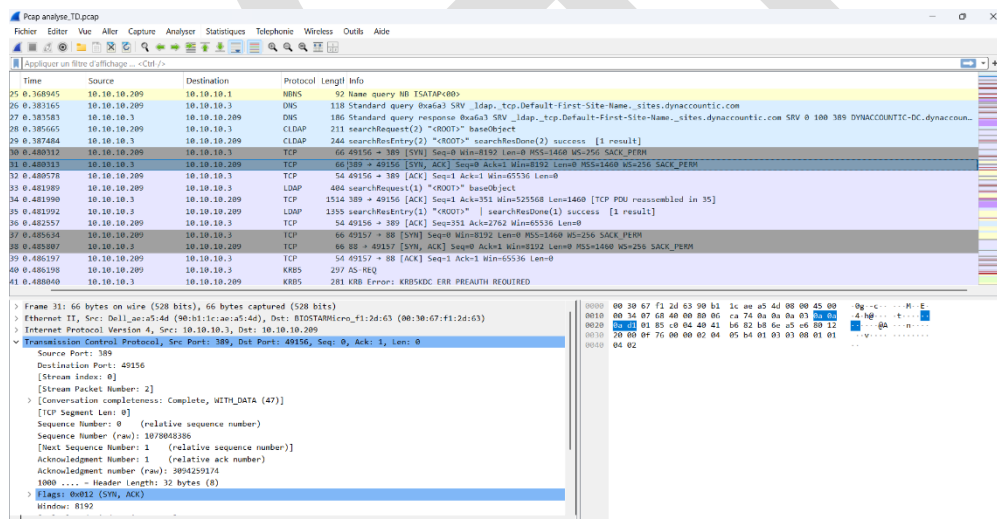
- Transmission en clair des identifiants, commandes et toutes les données qui circulent sans chiffrement.
- Aucune authentification une fois connecté. Possibilité de détournement de session et d'usurpation d'identité.
- Surface d'attaque élevée.

Quel est le protocole qui l'a remplacé ?

De nos jours, SSH (Secure Shell) est le plus utilisée. Il offre une communication chiffrée et une authentification robuste.

Partie 1 : Analyse de l'infection

Etape 1 : Identification du Three-Way



Le pcap(paquet capturé) commence par la séquence classique d'établissement de connexion :

1. **Initiation de connexion** : Client—[SYN (synchronisation)]----->Serveur .
2. **Accusé de réception et connexion** : Client—[SYN-ACK (synchronisation + reconnaissance)] <--
-----Serveur
3. **Confirmation de connexion** : Client—[ACK (reconnaissance)]----->Serveur

Etape 2 : Identification des IPs et des ports source/destination

IP client : 10.10.10.299

IP Serveur : 10.10.10.3

POUR LE SYN-ACK

- Port source : 389
- Port destination : 49156

NB : Le port **389** est le port standard **LDAP**. Cela indique du trafic d'authentification Active Directory/domaine dans la capture.

Etape 3 : Présentation de NetBIOS et de ses services

NetBIOS n'est pas un protocole unique mais une suite de services réseau qui fournissent la résolution de noms, la gestion de sessions et la distribution de datagrammes sur les réseaux Windows legacy.

Service	Fonction	Port	Protocole
NBNS(NetBIOS Name Service)	Résolution de nom équivalent au DNS	137	UDP
NBDS (NetBIOS Datagram Service)	Messagerie sans connexion	138	UDP
NBSS (NetBIOS Session Service)	Sessions orientées connexion (SMB)	139	TCP

Etape 4 : Filtrage du trafic http

Fichier Editer Vue Aller Capture Analyser Statistiques Téléphonie Wireless Outils Aide

tcp.dstport == 80

No.	Time	Source	Destination	Protocol	Length	Info
415	19.424134	10.10.10.299	23.43.62.200	TCP	66	49182 → 80 [SYN] Seq=0 Win=0 Len=0 MSS=1460 WS=256 SACK_PERM
417	19.448732	10.10.10.299	23.43.62.200	TCP	54	49182 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0
419	19.459252	10.10.10.299	23.43.62.200	HTTP	151	GET /rcsl.txt HTTP/1.1
421	19.478263	10.10.10.299	23.43.62.200	TCP	54	49182 → 80 [FIN, ACK] Seq=90 Ack=189 Win=64061 Len=0
424	19.479143	10.10.10.299	23.43.62.200	TCP	54	49182 → 80 [ACK] Seq=99 Ack=181 Win=64061 Len=0
676	193.544088	10.10.10.200	95.110.193.132	TCP	66	49199 → 80 [SYN] Seq=0 Win=0 Len=0 MSS=1460 WS=256 SACK_PERM
678	194.094801	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0
679	194.094801	10.10.10.200	95.110.193.132	HTTP	133	GET /ser0410.bin HTTP/1.1
683	194.251525	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=2921 Win=64240 Len=0
686	194.401890	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=5841 Win=64240 Len=0
689	194.402289	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=8761 Win=64240 Len=0
692	194.551656	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=11681 Win=64240 Len=0
695	194.551889	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=14401 Win=64240 Len=0
700	194.552412	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=17521 Win=64240 Len=0
701	194.552538	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=20441 Win=64240 Len=0
704	194.760811	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=23761 Win=64240 Len=0
707	194.767134	10.10.10.200	95.110.193.132	TCP	54	49199 → 80 [ACK] Seq=80 Ack=26281 Win=64240 Len=0

> Frame 415: 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on 0
> Ethernet II, Src: R00510M100 (f2:2d:6f:00:30:67), Dst: Cisco_Fe2c20e (08:00:07:b1:fe:c2:0e)
> Internet Protocol Version 4, Src: 10.10.10.299, Dst: 23.43.62.200
> Transmission Control Protocol, Src Port: 49182, Dst Port: 80, Seq: 0, Len: 0

0000 00 09 7b fe c2 0a 00 30 67 f1 2d 6f 00 00 40 00 ... 0 g...f
0010 00 34 00 f3 40 00 00 00 0f 03 0a 0a d1 17 2b ... 4 @...+
0020 3a c8 10 1a 00 50 06 7e 06 18 00 00 00 00 00 02 ... >...P...
0030 20 00 12 3e 00 00 02 04 05 54 01 03 00 01 01 ... 2...P...
0040 04 02

Transmission Control Protocol (Brg, 32 octets) Paquets : 3297 - Affichés : 120 (3.6%) Profil : Default

Pour faire un filtre de port on utilise **tcp.dstport == num du port**. Vu que ces http que nous cherchons à filtrer, nous allons entrer le port **80** qui est le port qu'il utilise par défaut. Ici nous avons **120 paquets affichés**.

Etape 5 : Enumération de l'hôte via le filtrage IP

Filtre utilisé : ip.src == 10.10.10.209

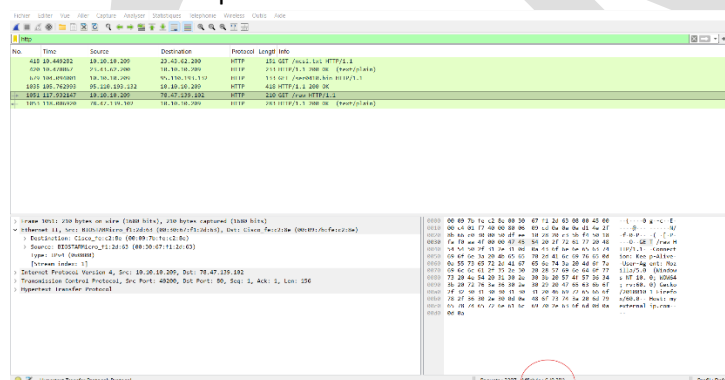
```
> Frame 1193: 110 bytes on wire (880 bits), 110 bytes captured (880 bits) on 0
> Ethernet II, Src: BIOSTARMicro_f1:2d:63 (00:30:67:f1:2d:63), Dst: Cisco_fe:c2:8e (00:09:7b:fe:c2:8e)
  > Destination: Cisco_fe:c2:8e (00:09:7b:fe:c2:8e)
  > Source: BIOSTARMicro_f1:2d:63 (00:30:67:f1:2d:63)
  Type: IPv4 (0x0800)
  [Stream index: 1]
> Internet Protocol Version 4, Src: 10.10.10.209, Dst: 10.10.10.1
> User Datagram Protocol, Src Port: 137, Dst Port: 137
> NetBIOS Name Service
```

- **En jaune :** Nom de la machine
- **En orange :** Adresse Mac
- **En bleu :** le port
- **En rose :** le nom du NetBIOS

Etape 6 : Décomposition des paquets http

1. Pour le nombre de paquet :

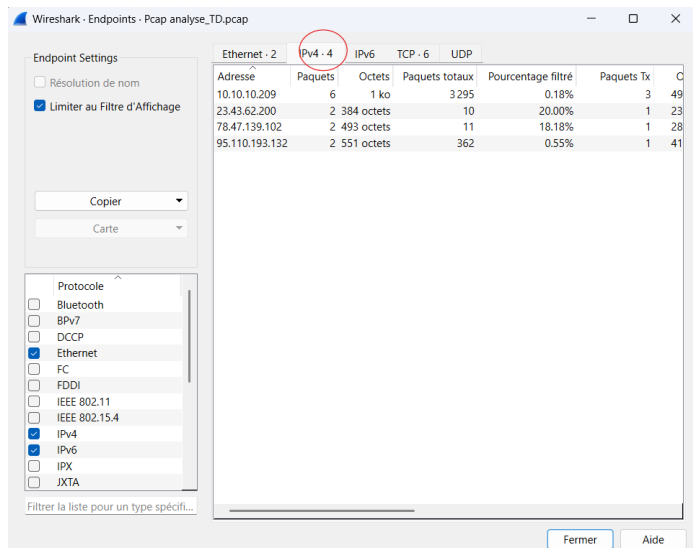
Filtre utilisé : 'http'



2. Pour le nombre de réponse :
Filtre utilisé : 'http.response'
3. Pour le nombre de requête :
Filtre utilisé : 'http.request'

Etape 7 : Adresses IP communiquant sur notre filtre http mis à l'étape 6

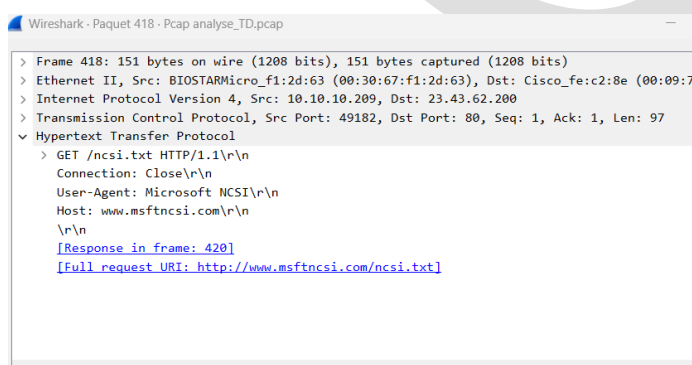
Les adresses IPs communiquant sur le même port se trouvent dans l'onglet **statistique**-> **Point de terminaison** et ensuite cliquez sur **ipv4** comme dans l'image si après.



Etape 8 : Trouver le User-Agent

Filtre utilisé : 'http.request'

En entrant le filtre ci-dessus et en développant n'importe quelle requête http-> 'Hypertext Transfer Protocol' on obtient :



User-agent : 'Microsoft NCSI'

Type de requête : Vérification de connectivité Windows(NCSI)

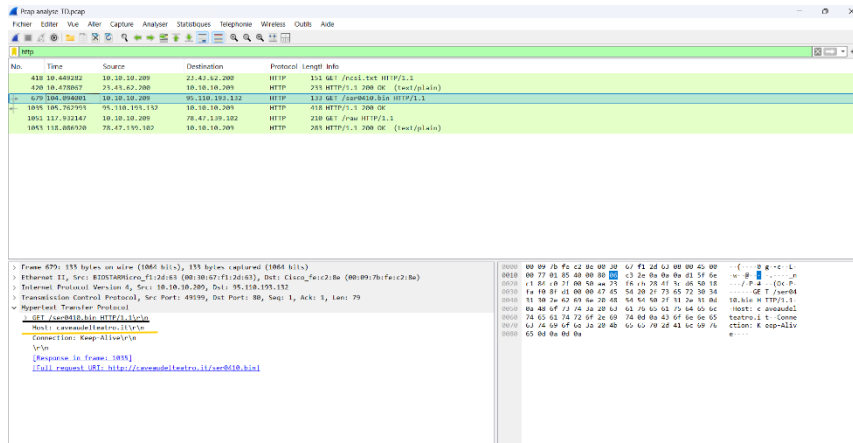
Système d'exploitation : Windows

NB : 'Microsoft NCSI' est un service Windows intégré qui vérifie la connectivité internet. Cela nous confirme que notre machine infectée tourne sous **Windows**.

Etape 9 : Identification du FQDN et du fichier malveillant

FQDN (fully Qualified domain name) est le nom complet et non ambigu identifiant un hôte sur le réseau.

Dans notre cas, après que la victime se soit connectée sur Microsoft, wireshark révèle une redirection sur un site compromis que je vais vous montrer tout en bas.



FQDN compromis : 'caveaudelteatro.it'

Fichier malveillant : '/ser0410.bin'

Etape 10 : Point à savoir sur la segmentation TCP et gestion des gros paquets

La taille maximale d'un segment TCP est de **1460 octets**.

Lorsque les dépassent, il utilise deux mécanismes pour gérer la transmission :

1. **La fragmentation** : Les gros paquets sont découpés en segments plus petits correspondant au MTU(maximum transmission unit).
2. **Le réassemblage** : Le récepteur reconstruit les données originales à partir des fragments.